SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

I D.Hasini/192425147 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: D.Hasini

ANSWERS

1. OSINT email enumeration of tesla.com using theHarvester (Kali Linux) - findings, attack use and countermeasures. (20 Marks)

Scope note: the assessment uses only public sources (passive OSINT) against a domain named in the assignment, for academic purposes. No system is attacked or logged into.

Understanding of Social Engineering Scenario (20%)

OSINT (open-source intelligence) is the reconnaissance phase of an attack: the attacker collects information that the organization has already made public, without touching its systems. theHarvester queries public sources such as search engines, certificate-transparency logs, DNS data sets and public databases to list e-mail addresses, sub-domains, host names and IP addresses for a domain. For a large company such as Tesla, the information shows the **people, services and infrastructure** that a social engineer can choose to target. The task is therefore to run the tool, organize the results by role, and explain the resulting risk.

Commands executed (Kali Linux):

```
theHarvester -d tesla.com -b all -l 200 -f tesla_report
# passive sources only (alternative):
theHarvester -d tesla.com -b duckduckgo,crtsh,rapiddns,hackertarget -l 200
# results are saved to tesla_report.html / tesla_report.xml (emails, hosts, IPs)
dig +short A www.tesla.com            # resolve a discovered host to its IP
whois tesla.com                       # registration contacts (public data)
```

Identification of Attack and Vulnerabilities (20%)

Information collected and categorization. The output of the tool is grouped into four lists: e-mail addresses, sub-domains/hosts, IP addresses and (if available) public employee names. The addresses found are categorized by likely role from the local part of the mailbox and the context in which they appear:

Role group	Typical address pattern	What an attacker can learn / abuse
Support / Customer care	support@, service@, help@, care@	High-volume inbox; staff are trained to respond quickly to customers - suitable for pretexting and malicious attachments.
Sales	sales@, orders@, info@, firstname.lastname@	Reveals the e-mail naming format; sales staff open mails from unknown senders regularly.
Human Resources	hr@, careers@, recruitment@, jobs@	Expects CVs and attachments from strangers - an ideal delivery route for malware in a fake resume.
Administration	admin@, office@, press@, legal@, accounts@	Authority roles; useful for impersonation, invoice and payment fraud.
Technical / IT teams	it@, security@, abuse@, devops@, webmaster@	Holds privileged access; the target for credential harvesting and fake alerts.

Hosts and sub-domains (for example www, shop, service, auth, vpn, mail or dev-style names) show which systems exist: customer portals, login pages and mail gateways. Resolving each host gives its **IP address** and hosting provider, which maps the organization's external footprint. *Note: the exact addresses and hosts depend on the live run of the tool; the table above lists the role categories and patterns used to classify whatever the run returns, and the screenshot of the tool's output from the lab machine belongs beside this section.*

How the information assists the reconnaissance phase: it shortens target selection (who to contact), reveals the address format (so any employee's address can be guessed), shows which login and mail systems to imitate, and gives the technical footprint for later scanning.

Application of Security Concepts and Countermeasures (25%)

Attack techniques the data supports:

- **Spear-phishing:** using the discovered role and e-mail format, the attacker writes a personalized message (for example a “document for HR review” or “order issue”) to a specific person; personalization raises the success rate far above mass phishing.
- **Credential harvesting:** knowing real login hosts and branding, the attacker clones a sign-in page on a look-alike domain, and the mail directs targets to it; stolen passwords are tried against VPN, mail and portals (credential stuffing).
- **Impersonation:** a pretext as a manager, colleague, vendor or IT support using real names, roles and the correct address format; spoofed or look-alike domains make the sender appear genuine (business e-mail compromise).

Countermeasures (at least five):

- Minimize public exposure: use role-based or contact-form addresses instead of personal addresses on websites; avoid publishing staff lists with e-mail addresses; remove old data from search engines.
- Enforce **SPF, DKIM and DMARC** to block spoofing of the domain, and monitor for look-alike (typosquat) domains.
- Deploy **multi-factor authentication** everywhere so that harvested passwords are not enough; use a password manager.
- Run regular **security awareness training and phishing simulations**; teach staff to verify unusual requests through a second channel.
- Use a **secure e-mail gateway** (URL rewriting, attachment sandboxing, external-sender banners) and filter risky attachments.
- Harden DNS and certificate hygiene: remove unused sub-domains, avoid exposing internal names, and monitor certificate-transparency logs for rogue certificates.
- Define an incident-reporting process and a verification policy for requests involving payments, passwords or data.

Risk Analysis and Decision Making (20%)

Threat	Likelihood	Business impact	Risk	Decision / priority
Spear-phishing of HR/support	High	Malware, data theft	High	Awareness training + mail gateway (immediate)
Credential harvesting	High	Account takeover, data breach	High	MFA and DMARC (immediate)
Impersonation / BEC	Medium	Financial loss, reputation	Medium-High	Verification policy, domain monitoring
Host/IP mapping for later scans	Medium	Eases later technical attacks	Medium	Reduce exposed hosts, patching, monitoring

Decision: information that is already public cannot be taken back, so the defensible strategy is to make that information *less useful* to an attacker: reduce exposure, add authentication and verification, and train staff. Priority goes to MFA and e-mail authentication because they stop the most likely attacks.

Clarity, Documentation and Technical Presentation (15%)

Report structure: (1) Objective and scope, (2) Tools and commands, (3) Findings (e-mails by role, hosts, IPs, with screenshots of the theHarvester output), (4) Attack analysis, (5) Risk analysis, (6) Recommendations, (7) Conclusion. The commands, categorization table, risk matrix and countermeasures above form this report.

2. GoPhish phishing awareness simulation with dummy employee accounts - template, campaign, monitoring, report and recommendations. (20 Marks)

Understanding of Social Engineering Scenario (20%)

Phishing is the most common social-engineering attack: a deceptive e-mail tricks the user into clicking a link, entering credentials or opening an attachment. A **phishing awareness simulation** measures how employees behave in a safe, authorized environment, so that training can be targeted. GoPhish is an open-source framework that sends simulated phishing e-mails and records the delivery, opens, clicks and submitted data per user. In this lab only dummy employee accounts are used, so no real person or data is affected, and the purpose is education, not punishment.

Simulation set-up (steps performed in GoPhish):

Step	GoPhish component	Configuration used
1	Sending Profile	SMTP server of the lab mail system (for example localhost:25), from-address such as it-support@lab-company.test
2	Users and Groups	Group “Dummy Employees” with the dummy accounts provided (name, e-mail, position)
3	Email Template	Subject “Action required: verify your account”, awareness-style body with a link variable {{.URL}} and the tracking pixel {{.Tracker}}
4	Landing Page	Cloned sign-in page that captures submitted data for the exercise and then redirects to an “awareness” page
5	Campaign	Select template, page, profile, group, set the launch time and the GoPhish URL, then launch
6	Monitoring and report	Dashboard timeline: Email Sent, Email Opened, Clicked Link, Submitted Data, Email Reported; export as CSV/PDF

Template used (summary): a short message from a fake “IT Support” that creates mild urgency and asks the user to confirm the account through a link. Typical lure features are deliberately included so that they can be taught afterwards: generic greeting, urgency, an unfamiliar link, and a request for credentials.

Identification of Attack and Vulnerabilities (20%)

- **Attack type:** mass phishing / credential-harvesting simulation (social engineering through e-mail).
- **Human vulnerabilities tested:** trust in authority (IT), urgency, curiosity and not checking the sender or link.
- **Technical weaknesses exposed:** the message reaches the inbox (filtering gaps), links are not rewritten or checked, and a password alone gives access (no MFA).
- **Assets at risk:** user credentials, mail accounts and the data and systems behind them.

Application of Security Concepts and Countermeasures (25%)

Metrics generated by the report (definitions): **Delivery rate** = e-mails delivered / e-mails sent × 100; **Open rate** = e-mails opened / delivered × 100 (measured with the tracking pixel); **Click rate** = users who clicked / delivered × 100. Two further metrics are useful: submitted-data rate and report rate.

Sample campaign results (20 dummy lab accounts - replace with the figures from your own GoPhish dashboard):

Metric	Count (of 20)	Rate
Emails sent / delivered	20 / 20	Delivery rate 100%
Emails opened	14	Open rate 70%
Link clicked	8	Click rate 40%

Metric	Count (of 20)	Rate
Data submitted on landing page	4	20% (half of the clickers)
Reported as phishing	3	15%

Countermeasures and awareness recommendations based on these results:

- **Training:** deliver short, regular awareness sessions using this campaign as a case study; show the red flags in the template (urgency, mismatched link, generic greeting).
- **Retesting:** repeat simulations every quarter with different lures; track whether the click rate falls below 5% and the report rate rises above 70%.
- **Reporting:** introduce a “Report phishing” button and reward people who report; make the reporting path simple.
- **Technical controls:** SPF/DKIM/DMARC, mail gateway with link protection and attachment sandboxing, and **MFA** to neutralize stolen passwords.
- **Policy:** a clear rule that IT never asks for passwords by e-mail and a verification step for unexpected requests.
- **Support for clickers:** immediate feedback page and extra coaching for users who submitted data, without blame.

Risk Analysis and Decision Making (20%)

A 40% click rate and 20% submission rate show a high likelihood of a real attack succeeding: the main impact would be account compromise and data exposure. The open rate is high, which means the lure is believable. The decision is to prioritize MFA and training first (largest risk reduction), and then e-mail filtering and policy. The 15% report rate shows some good behaviour that should be built upon.

Clarity, Documentation and Technical Presentation (15%)

The report contains: objective, tool and set-up, campaign configuration, results table, analysis, recommendations and conclusion. Screenshots of the GoPhish template, campaign dashboard and results page are placed with the matching steps.

3. Nmap aggressive scan (-A) of scanme.nmap.org - information gathered and its use in a social-engineering attack on the IT support team. (10 Marks)

Scope note: scanme.nmap.org is a host that the Nmap project provides for people to practise scanning legally; heavy or repeated scans should be avoided.

Understanding of Social Engineering Scenario (20%)

The Nmap **aggressive scan** (`-A`) combines OS detection (-O), service/version detection (-sV), default NSE scripts (-sC) and traceroute. It gives an attacker a detailed technical profile of the target: operating system, open ports, and the exact software versions. The question asks how that technical information can be used for a **non-technical** attack - social engineering against the IT support (help desk) staff - and how to defend against it.

Command executed:

```
nmap -A scanme.nmap.org
# or, saving the output for the report:
nmap -A -oN scanme_aggressive.txt scanme.nmap.org
```

Typical results documented for this host (confirm against your own scan output and attach its screenshot):

Item	Typical finding
Operating system	Linux (Ubuntu) kernel 3.x/4.x
22/tcp	ssh - OpenSSH 6.6.1p1 Ubuntu
80/tcp	http - Apache httpd 2.4.7 (Ubuntu)
9929/tcp	nping-echo (Nping echo service)
31337/tcp	Elite (a service sometimes shown as tcpwrapped)

Identification of Attack and Vulnerabilities (20%)

- **Information leakage:** service banners reveal the software and versions (for example an old OpenSSH and Apache); the OS details reveal the platform and its age.
- **Vulnerabilities:** outdated versions are likely to have publicly known flaws; unusual open ports (9929, 31337) suggest extra or unmanaged services.
- **Attack type:** pretexting/vishing against the help desk, using technical facts to appear credible.

Application of Security Concepts and Countermeasures (25%)

Attack methodology (described from the attacker's point of view):

- **1. Reconnaissance:** run the scan and record OS, ports and versions; research the IT team and ticket procedures.
- **2. Pretext building:** prepare a believable story, such as a remote employee or contractor who "cannot connect over SSH to the Ubuntu server running Apache", mentioning the exact versions to sound like an insider.
- **3. Contact:** phone or e-mail the IT support team, creating urgency ("manager needs it before a deadline") and authority.
- **4. Request:** ask for a password reset, a temporary account, firewall rule change or the current admin contact; the technical detail lowers the support agent's suspicion.
- **5. Exploitation:** use the obtained access or information to log in, or to launch a technical attack on the outdated services.

Defensive recommendations:

- **Verification procedure:** identify every caller through a second channel (call back on the registered number, ticket ID, manager approval) before any reset or access change.
- **Policy:** no password disclosure or reset by phone/e-mail; all requests through a ticketing system; privileged changes need two-person approval.
- **Training:** train the help-desk with pretext scenarios and simulated vishing calls; teach that correct technical jargon does not prove identity.
- **Reduce leakage:** hide version banners, close unused ports (9929, 31337), patch Apache and OpenSSH, restrict SSH by IP/VPN, enable MFA and key-based login.
- **Monitoring:** log and alert on repeated scans, resets and failed logins; use an IDS/IPS.

Risk Analysis and Decision Making (20%)

Risk is **medium to high**: scanning is easy and free, while a successful call to the help desk could give an attacker valid access without any technical exploit. The decision is to rely first on process controls (verification and approvals), which stop the human attack path, and then on technical hardening that removes the version information and the vulnerable services.

Clarity, Documentation and Technical Presentation (15%)

Phase	Attacker action	Defence
Recon	Nmap -A: OS, ports, versions	Hide banners, patch, close ports, IDS
Pretext	Story using real technical detail	Awareness training for IT staff
Request	Ask for reset / access	Callback verification, ticketing, approvals
Exploit	Login or vulnerability attack	MFA, logging, least privilege

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.